

**Examination paper released:** 29.11.2024 10:00

**Examination deadline:** 06.12.2024 10:00

Academic contact during examination: Martin Bergo

[martin.bergo@kristiania.no](mailto:martin.bergo@kristiania.no), +47 47 82 13 45

**Exam format:** Individual written home examination

**Final report format:** A4 format, either LaTeX, Word or Markdown format with the Arial font in size 11 and 1.0 line spacing. You can submit the final report as .docx, PDF or Markdown file. **Important:** When submitting your exam, attach the language in the end of the file name, divided by an "\_" (e.g. "Candidate001\_English.docx" or "Candidate001\_Norsk.pdf").

**Grading scale:** The Norwegian grading system uses the graded scale A - F, where A is the best grade, E is the lowest pass grade, and F is fail.

**Weighting:** 100% of the overall grade

**Support materials:** All support materials are allowed - including the course books, course slides and course practical task.

**Plagiarism control:** We expect your independent work. Use citations and quotations if there is material you want to include in the report. This includes text and other material e.g. like figures, tables.

Use APA7 for referencing from the course source. Also, only use intext citations. This means, cite at the exact place in a sentence whenever you quote or take information from a source. Information: When it comes to citation of the books, reference the page(s). For the slides, refer to which lecture (1-12) and which slide number (number on lower right side of a slide, not the page number which is shown in your PDF reader).

**Task format:** Both task A and B is mandatory. You are free to solve the tasks however you see fit, there is no constraints or requirements besides that one should use a "cloud" solution. What is defined as "cloud" is up to you in this scenario, regardless of how you approach the tasks, configuring and deploying the required resources is mandatory. As well is testing and verification of the functionality of the resources that you deploy.

It is also mandatory to document the functionality, or lack of functionality. If there is any errors, or challenges that breaks the indented functionality, this should be documented as well.

**Leaning outcomes as per course description:**

## **Knowledge. The student..**

- Can define and explain how cloud services work
- Can define and explain the development methodology DevSecOps and how this differs from traditional product development
- Can define and explain the role of a Web Application Firewall and how a WAF can be part of a security architecture
- Can explain the difference between a Cloud Native application and a cloud migration that uses the Lift And Shift methodology
- Can define and explain how cloud solutions are secured and what differences and similarities this is in relation to internal servers
- Can explain the terms Software as a Service, Platform as a Service and Security as a Service

## **Skills. The student..**

- Can use, configure and manage security in a cloud solution
- Can install and configure a Web Application Firewall and use it to protect a cloud solution
- Can use security and vulnerability analysis tools integrated with the cloud solution
- Can use integrated logging in cloud solutions and understand how these logs can be integrated with a SIEM tool

## **General Competence. The student..**

- Reflect the architectural requirements and give and advice about security architecture and implementation of security solutions in cloud services
- Describe and define the advantages and disadvantages of establishing or moving a project / service to the cloud from a security perspective

# **Exam Task**

## **Scenario**

You are a consultant hired by the CTO in the company "Strelizia", this company is in a very tough situation where they are highly constrained on money. The company is developing new products that require a very high degree of flexibility on their compute resources.

They have attracted customers all over the world, but have not yet signed any contracts, if they land these customers they might need to serve customers on a global scale. But only if the customer signs a contract with "Strelizia".

Strelizia also have legacy applications running on physical servers in their basement, this is a huge issue as these applications are mission critical. They do **NOT** have the time to upgrade

the application, and fix the insecurities and vulnerabilities within these applications.

Unbeknownst to this company, there is a flood coming in two weeks, this flood will destroy all the legacy hardware in the basement. This means that time is of the essence, the CTO has hired **you** to help them use a cloud solution, **you** need to move the legacy application as soon as possible from the basement to a cloud provider.

The applications is also vulnerable, and not fixable, **you** need to find a solution on how to protect the legacy applications from the most common attacks.

The CTO have also stated that he has written some IaC (Infrastructure as Code) Terraform code before, and would very much like the deployment to be done in a IaC tool. But due to the time constraint, this is not required. But heavily wanted by the CTO.

The CTO also admits that they have no backups, they are very vulnerable. How can this be fixed in the cloud provider?

## Task A (70% of the grade)

**Plan** your deployment based on the scenario and the Task A. 1 -> 2.

The plan should be as detailed as possible, DO NOT plan while you perform the configuration or deployment of resources. After you have finished writing your plan, make a copy, if changes are made to the plan, document the changes and a justification for the change.

Its normal and expected that the plan will change during the tasks.

**Document** your configurations and deployments, **VERIFY** configuration. Is the configuration secure? It is very important that the documentation reflects the actual deployed resources. If you are using a IaC tool (Terraform), provide the statefile in your delivery. If using click-ops, deliver screenshots, and description of **ALL** resources deployed, **IF** using click-ops, you should also include checklists/verification and other documents that you have used to verify your configurations.

Remember our goal is to provide a secure solution, if documentation and reports does not reflect the actual deployed resources. Then this is a strong indication of a insecure environment.

### Task A. 1

Using the cloud provider of your choice, deploy a compute resource that exposes a HTTP service (VM, Docker, or similar), and all other supporting resources or infrastructure components.

Protect this compute resource by deploying a Web Application Firewall.

Use a security and vulnerability analysis tool, use this tool multiple times to show the changes

or progression of the cloud infrastructure in regards to security.

## **Task A. 2**

Using the integrated logging in the cloud provider or solution. Show and document the logs generated when deploying and operating your infrastructure, explain in detail how these logs can be integrated with a SIEM tool. And what kind of benefit you would get from having these logs in a SIEM tool, be as specific as you can!

## **Task A. 3**

Include all code, documentation written in this task. Also include screenshots from the cloud provider where it is needed. Remember to include the .tfstate file if Terraform is used.

## **Task B (30% of the grade)**

Answer and elaborate on the following questions and or statements.

1. How does cloud services work? What is the biggest benefit of using cloud services from a financial perspective?
2. What is the benefits from a technical perspective of using cloud servies?
3. What is the difference between the different operating models within a cloud service? (IaaS, PaaS, SaaS). Who has responsibility of what?
4. How are cloud services secured? Is there any public examples of where cloud services were not secured properly?
5. What is a Cloud Native application?
6. Define and explain the different cloud migration strategies.
7. What is a Web Application Firewall? What would one use such a firewall for?
8. Define and explain what DevSecOps is, and how this differs compared to more traditional product development approaches.
9. Using Azure, AWS or GCP. What is the most essential knowledge one should acquire to use these cloud providers in a secure way? Is there any best-practices, or architecture guides?
10. What are the downsides of using Cloud? Is there any benefit of not using cloud?